

Mini Quiz Pentest Scope Brief

Prepared for external security auditors | Draft dated June 2, 2026

Product Summary

Mini Quiz is a real-time multiplayer quiz product for Celo MiniPay users. Hosts schedule quiz games with USDT prize pools; players join by QR/deep link, answer timed questions, see live leaderboards, and top finishers are paid automatically on Celo when a game ends.

System Scope

Surface	Entry point	Expected audit focus
Player app	https://miniquiz.club	Mobile MiniPay quiz flow: join, lobby, answer, reveal, leaderboard.
Admin app	https://admin.miniquiz.club	Desktop console: auth, quiz creation, live monitor, players, payouts.
Public API	https://api.miniquiz.club	Fastify REST API, admin/player routes, public quiz and leaderboard reads.
Realtime	/rooms/:code/events	SSE gateway for room events, live scoring, and admin answer distribution.
Backend workers	DOKS cluster	Scheduler/finalizer, score worker, payout worker, migrations, capacity prewarmer.

Primary User Flows to Test

- Player joins a room, receives a room token, connects MiniPay wallet, submits answers, and receives realtime quiz state over SSE.
- Admin signs in, creates/schedules quizzes, monitors live games, ends games, reviews users, and manages payout records.
- Backend scheduler starts/ends eligible quizzes, score worker processes accepted answers, and payout worker creates/sends approved prize transfers.

Security-Sensitive Areas

Area	Guidance
In scope	Authentication and authorization, player identity/session tokens, admin flows, quiz lifecycle controls, answer submission, realtime events, leaderboard integrity, payout request/ledger behavior, API validation, infrastructure manifests, and secret handling patterns.
Sensitive assets	Admin accounts, NextAuth/backend JWT signing secret, treasury private key, Celo RPC access, Postgres data, Redis/NATS live state, payout transaction handling, player wallet addresses, and quiz/prize configuration.
Out of scope unless approved	Destructive blockchain transfers, live treasury fund movement, social engineering, denial-of-service beyond safe rate testing, Cloudflare or Vercel account takeover testing, and changes to production infrastructure.
Safe testing notes	Use staging/test data if available. If production must be touched, prefer read-only checks, low-volume requests, and coordinate any payout, load, or destructive scenarios before execution.

Recommended Audit Checks

- Auth/session boundaries between anonymous players, room JWTs, admin JWTs, and admin-only API routes.
- Input validation and abuse resistance for room joins, answer submissions, quiz creation, AI generation endpoints, payout retries, and user flagging.
- Realtime event authorization: room isolation, token handling in SSE, replay behavior, and leakage between player/admin event payloads.
- Game integrity: answer idempotency, timing windows, leaderboard consistency, quorum handling, manual early end behavior, and final standings used for payouts.
- Payout safety: rank-to-prize mapping, wallet address handling, retry behavior, failed transfer handling, treasury key exposure paths, and transaction logging.
- Infrastructure and dependency review: Dockerfile build/runtime stages, Prisma migration flow, Kubernetes manifests, sealed secrets, CORS, rate limits, and health endpoints.

Known Boundaries and Assumptions

The player and admin frontends are hosted on Vercel. The long-lived backend, realtime gateway, workers, Postgres, Redis, and NATS run in a single-region DigitalOcean Kubernetes cluster. Production SSE traffic is routed to the dedicated realtime gateway; Redis and NATS are internal services. The admin app does not connect directly to Postgres.

Coordinate before any production test that could spend funds, alter payouts, create high load, trigger worker scaling, rotate secrets, or modify infrastructure. Any newly discovered secret should be treated as sensitive and reported privately, not added to tickets or chat.

Useful Public URLs

- Player app: <https://miniquiz.club>
- Admin app: <https://admin.miniquiz.club>
- API health endpoint: <https://api.miniquiz.club/health>